A3-PS019-TC445 | Subnet Sovereigns

Personal-Data Discovery and Privacy Evidence Inventory

Samrudh K R	Team member	samrudhsamrudh7@gmail.com
Pranav Sarpangala	Team member	spranav1214@gmail.com
Dr. Animesh Giri	Mentor, PES University (EC Campus)	animeshgiri@pes.edu

AIORI Hackathon 3

October 13, 2026

Problem Description

Personal data piles up in undocumented tables and spreadsheets, detached from any declared purpose or retention period.

- PII spreads across unindexed database tables and legacy CSV files, with no record of why it is held or for how long [1][2].
- Regex-only scanners flag any 12-digit order ID as an Aadhaar number, so reviewers drown in false positives and real findings get lost.
- Declared purposes and retention schedules are detached from the columns that actually hold the data.
- **Our approach:** a modular Python scanner for synthetic CSV files and one SQLite database. Five data classes, dual-pass detection (regex, then checksum or context check), linking to declared purpose and retention metadata, and per-class precision and recall.
- **Boundary:** the output is a technical evidence inventory for human review. The tool makes no legal compliance decision, no lawful-basis determination and no universal data-flow inference.

Background

Why discovery must be technical, and why interpretation must stay with people.

- **DPDP Act 2023:** rests on purpose limitation and storage limitation. Personal data is processed for a specified purpose and erased once that purpose is served (Sec. 8(7)) [1]. The DPDP Rules 2025, notified in November 2025, phase in the operational duties over about 18 months [2].
- **Retention floors elsewhere:** other laws can require records to be kept (for example KYC records under PMLA and RBI directions, or financial records under the Income Tax Act) and can override erasure. A scanner therefore reports evidence; it never decides lawfulness.
- **Standards:** ISO/IEC 27701 controls A.7.2.1 (identify purposes), A.7.2.2 (lawful basis) and A.7.2.8 (records of processing) need a data inventory as input [4]; the NIST Privacy Framework likewise starts from an inventory [5].
- **Detection:** no single signal is reliable. Column-name hints, value patterns and checksums are combined, and quality is measured per class (precision and recall) on a small manually labelled test set.

Literature & RFC Review

The law, standards and validators that shape the design.

Source	Relevance	How we use it
DPDP Act 2023, DPDP Rules 2025, MeitY framework [1][2][3]	Purpose limitation, storage limitation, erasure, phased duties	Motivates purpose and retention fields; no legal logic is encoded
ISO/IEC 27701:2019 [4]	PIMS controls A.7.2.1, A.7.2.2, A.7.2.8	Shapes the evidence checklist and gap flags
NIST Privacy Framework v1.0 [5]	Data inventory as the basis of privacy risk management	Inventory columns; repeatable re-scan
Microsoft Presidio [6]	Open-source PII recognisers: regex, context, validators	Design inspiration; our engine is written from scratch
Verhoeff (1969) [7]; Luhn (1960) [8]	Checksums for Aadhaar and payment-card numbers	Second-pass validators that cut false positives
RFC 5322 [9]; ITU-T E.164 [10]	Email address syntax; international phone numbering	Email regex and phone-number parsing

Proposed Solution

A four-phase modular pipeline that finds candidate PII, links it to declared metadata and reports what is missing.

- **1 Ingest:** SQLite schema via PRAGMA table_info [11]; CSV files in 10,000-row chunks.
- **2 Detect:** configurable YAML rules; pass 1 regex candidates, pass 2 checksum or context validation.
- **3 Link:** set-intersection of findings with a declarations JSON; flags missing purpose or retention.
- **4 Report:** evidence inventory (JSON/CSV), configurable evidence checklist, gap report and per-class precision/recall. Wording stays 'candidate' and 'evidence'; no lawful-basis output.

Data class	Pass 1: candidate	Pass 2: validation
Aadhaar number	12 digits, first digit 2-9	Verhoeff checksum [7]
Credit card number	13-19 digit string	Luhn checksum [8]
Email address	RFC 5322-style regex [9]	Domain syntax checks
Phone number	Digit string plus column-name hint	E.164 parse [10]
Contextual PII (name, address, date of birth)	Column name and column type	Confidence weighting

Optimization Proposed

Dual-pass checks, schema-first scanning and chunked reads cut false alerts, scan cost and memory use.

Aspect	Before (baseline)	After (proposed)
Detection	Regex only	Dual-pass: regex, then Verhoeff, Luhn, E.164 or context check
False positives	Any 12-digit string flagged as Aadhaar	About 90% of random 12-digit strings rejected by the Verhoeff check
Scan cost	Regex over every cell	Schema first: skip boolean and timestamp columns, weight by column name [11]
Memory	Whole CSV loaded into RAM	Chunked reads (10,000 rows): flat memory footprint
Rule changes	Edit source code	Edit YAML rules and thresholds, re-run the evaluation
Metadata	Manual spreadsheet cross-check	Automatic linking; missing purpose or retention flagged
Evaluation	Anecdotal spot checks	Per-class precision and recall on a labelled test set

Solution Architecture & Design

Visual: UML component diagram of the four-phase scanner pipeline and its inputs.

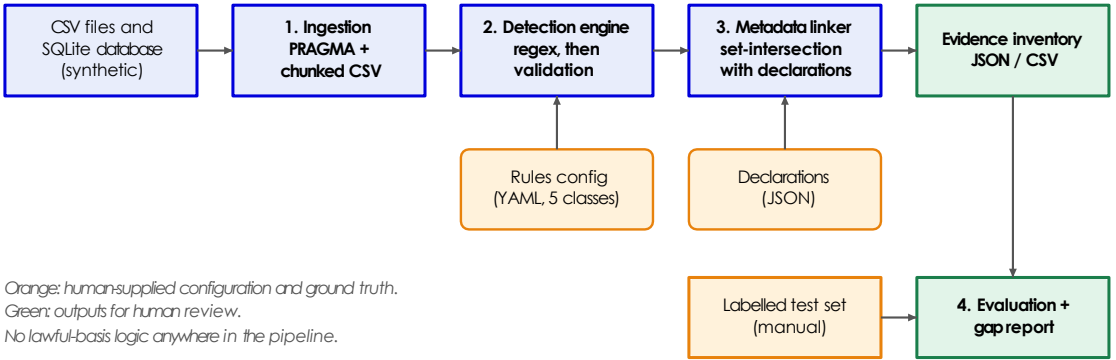
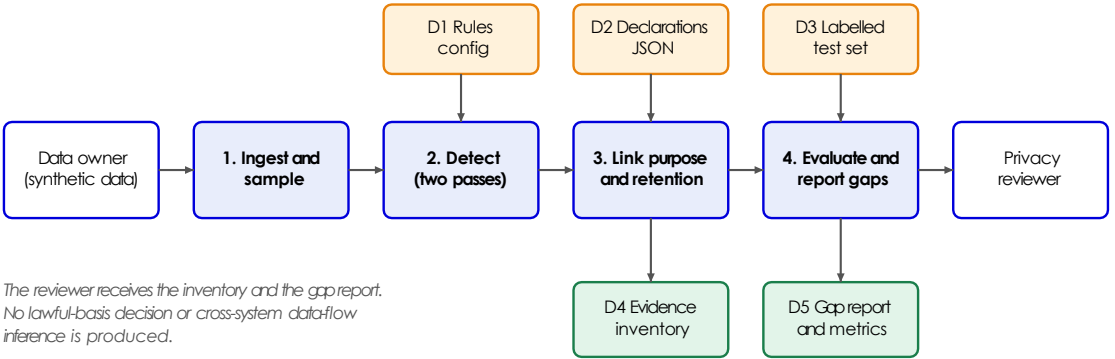


Figure: System Architecture UML Diagram

Data Flow Diagram

Overview of the architecture. Visual: level-1 data flow from synthetic sources to the evidence inventory.



The reviewer receives the inventory and the gap report. No lawful-basis decision or cross-system data-flow inference is produced.

Figure: Data Flow Diagram (DFD)

Deployment Timeline

Six milestones, tracked in the team's private GitHub repository.

Phase	Milestone	Deliverable
1	Private repository A3-PS019-TC445; add aiori-hackathon; transfer ownership	Repository, mentor access
2	Synthetic CSV and SQLite data, declarations JSON, hand-labelled test set	Datasets, ground truth
3	Ingestion (PRAGMA, chunked CSV) and dual-pass detection with YAML rules	Working detector
4	Metadata linker, gap flags, evidence checklist, JSON/CSV inventory	Inventory, gap report
5	Per-class precision and recall evaluation; rule and threshold tuning	Evaluation report
6	Upload this PDF to the repository; prototype demo with pseudocode	Report, demo

Methodology: iterative and mentor-visible. Each validator is unit-tested on known-valid and look-alike inputs, per-class precision and recall are re-run after every rule change, and work is committed to the private repository continuously.

Bibliography I

1 Government of India. “The Digital Personal Data Protection Act, 2023.” In: *Act No. 22 of 2023* (2023).

2 Press Information Bureau. “DPDP Rules, 2025 Notified.” Press release, 17 Nov. 2025. pib.gov.in, PRID 2190655.

3 Ministry of Electronics and Information Technology. “Data Protection Framework.” meity.gov.in/data-protection-framework.

4 ISO/IEC 27701:2019. “Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management – Requirements and guidelines.” (2019).

5 NIST. “NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0.” (2020).

6 Microsoft. “Presidio: Data Protection and De-identification SDK.” microsoft.github.io/presidio.

7 Jacobus Verhoeff. “Error Detecting Decimal Codes.” In: *Mathematical Centre Tracts* 29 (1969).

8 Hans Peter Luhn. “Computer for Verifying Numbers.” US Patent 2,950,048 (1960).

9 Pete Resnick (ed.). “Internet Message Format.” In: *IETF RFC 5322* (2008).

10 ITU-T. “The international public telecommunication numbering plan.” In: *Recommendation E.164* (2010).

11 SQLite. “PRAGMA table_info.” SQLite documentation. sqlite.org/pragma.html.

Thank You for Your Attention!